TECHNICAL REPORT | ZOHO CREATOR

# Implementing Security Features and Governance Practices in Zoho Creator

Access control, authentication, data protection and administration


| NAME | ROLL NUMBER | DEPARTMENT |
| --- | --- | --- |
| **Madhumitha P** | **241401049** | **CSBS** |


241401049

# 1 Abstract

Zoho Creator makes it easy to build and share business applications, often by people outside the IT department. That ease is also a risk: an app built quickly can expose sensitive data, give users too much power, or become impossible to track. This report studies how to **implement security features** and apply **governance and administration practices** in Zoho Creator.

The report explains the main threats to low-code applications, the security layers that Creator provides, and how to configure access control, authentication, data protection and audit. It then covers governance: the Governance module, environments for controlled releases, admin discipline and monitoring. A worked example, a Leave Management app, shows how the pieces fit together, and a checklist summarizes good practice.

> **Key idea:** Security in Zoho Creator is a **shared responsibility**. Zoho secures the platform, and the organization must configure roles, permissions, authentication and release control correctly.

# 2 Introduction

## 2.1 Why security and governance matter in low-code

Low-code speeds up development, and business users can now create apps with real company data. Without rules, this leads to over-shared records, weak sign-in settings, unreviewed changes and apps that nobody owns. **Security** protects data and access. **Governance** decides who may build, change, release and retire applications, and how this is monitored.

## 2.2 About Zoho Creator

Zoho Creator is a low-code platform for building web and mobile apps with forms, reports, pages, workflows and the Deluge scripting language. Apps are hosted in the Zoho cloud, so many protections are built into the platform, but each app still needs correct configuration.

## 2.3 Objectives

1. Identify the security risks in low-code applications.
2. Describe the security features available in Zoho Creator.
3. Explain how to configure access control, authentication and data protection.
4. Describe governance and administration practices, including environments and audit.
5. Provide a worked example and a practical checklist.

### 2.4 Scope and method

The report is based on public Zoho Creator documentation and help pages, plus a design example. Features and availability can depend on the Creator plan and version, so confirm them in the current documentation and in your own account before applying them.

## 3 Security Risks in Low-Code Applications

Most problems in low-code apps come from configuration and process, not from the platform itself. The table lists common risks and the area that addresses each.

| Risk | What can go wrong | Main control |
|---|---|---|
| Unauthorized access | Someone signs in as another user or without approval | Authentication, SSO, MFA, IP restrictions |
| Over-sharing of data | Users see records or fields they should not | Permissions, roles, data sharing rules, field permissions |
| Sensitive data exposure | Personal or health data is visible, exported or stored in plain form | Encryption, masking, PII and ePHI settings |
| Excessive privileges | Too many users can export, delete or bulk edit | Least-privilege permissions |
| Insecure integrations | Keys or tokens are written in scripts, or APIs are open | Connections, API security, secure Deluge practices |
| Uncontrolled changes | A faulty change goes live and breaks the app or data | Environments, testing, review |
| App sprawl and shadow IT | Unknown apps run with company data and no owner | Governance, inventory, standards |
| Weak accountability | Nobody can tell who changed what | Audit trail and logs |

## 4 Security Architecture of Zoho Creator

### 4.1 Platform-level protection

According to Zoho's documentation, Creator follows a security-by-design approach with an OWASP-based security framework. Stored data is encrypted with data encryption keys (DEK), which are further protected by a key encryption key (KEK) managed by Zoho. Data in transit is protected with HTTPS and TLS. Zoho states that Creator is certified for ISO/IEC 27001 and supports GDPR readiness and HIPAA compliance, with features such as role-based PII and ePHI controls, encryption and masking.

### 4.2 Defence in depth

A strong design uses several layers, so that a failure in one layer does not expose everything. The figure shows how Creator's features map to five layers.

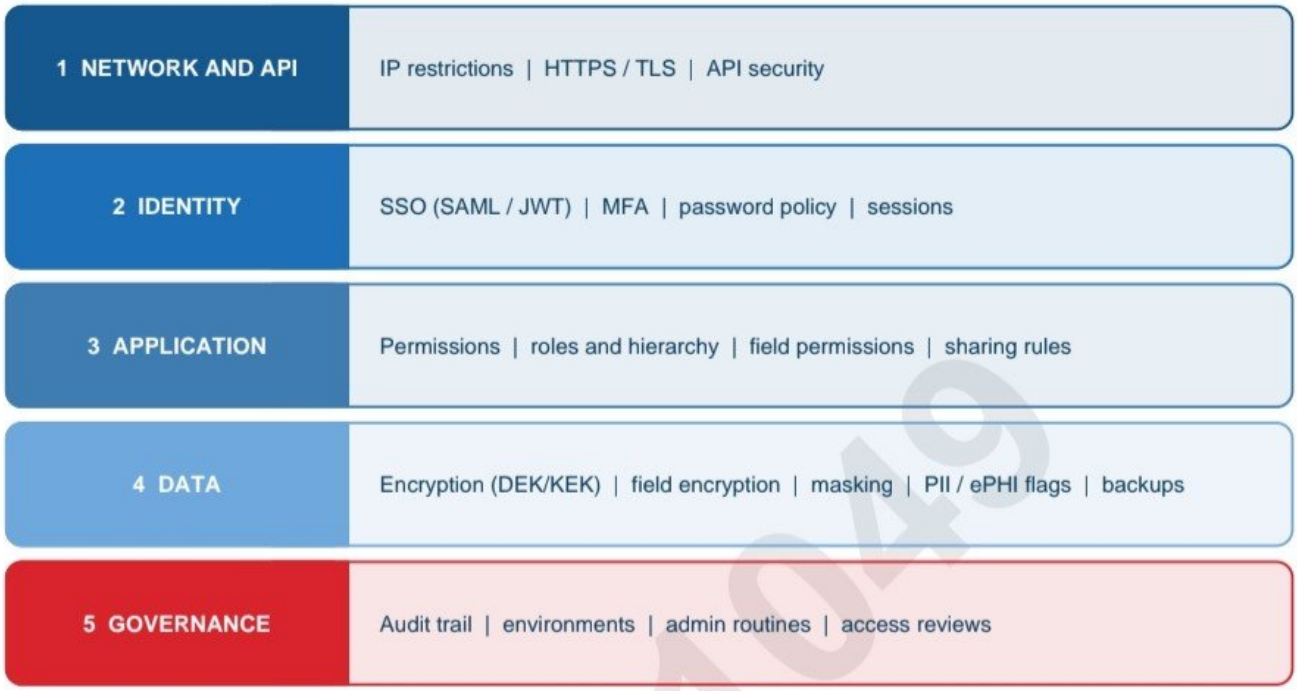



*Figure 1: Defence in depth with Zoho Creator security features*

### 4.3 What the organization must configure

The platform provides the tools, but the following are decided by the organization: who gets an account, which roles and permissions exist, how people sign in, which fields are sensitive, how changes are released, and how activity is reviewed. The rest of this report covers these choices.

## 5 Access Control: Users, Roles and Permissions

### 5.1 Building blocks

| Mechanism | Purpose | Notes |
|---|---|---|
| Permissions | Define what a user may do with each form, report or page | Two default permissions, Read and Write, plus custom permissions for view, edit and delete; available in all plans |
| Module-level access | Turn components of the app on or off for a group | Controls forms, reports and pages |
| Field permissions | Decide who can see or edit each field | Useful for salary, ID numbers or notes |
| Roles and role hierarchy | Model the reporting structure so managers can see their team's data | Hierarchy decides upward visibility |
| Data sharing rules | Share specific data with users or roles beyond the hierarchy | Zoho notes that sharing rules can override the role hierarchy |

241401049

| Mechanism | Purpose | Notes |
|---|---|---|
| PII and ePHI settings | Mark fields as personal or health data and control their visibility | Helps with privacy rules |

### 5.2 Principle of least privilege

Give every user only what the job needs. Zoho's best-practice guidance advises limiting the **Export, Delete, View All and Bulk Edit** permissions, because these allow large-scale data loss or leakage. Start with minimal permissions and add access when there is a clear reason.

### 5.3 Combining the mechanisms

A typical pattern is to use **permissions** for what each group can do, **roles** for who sees whose records, **field permissions** for sensitive columns, and **sharing rules** for exceptions. Keep the number of roles small and named by job function so that they stay understandable.

> **Tip:** Test every role by signing in as a sample user of that role, or by using demo or test users in the development and stage environments, before releasing to production.

## 6 Identity and Authentication

### 6.1 Single sign-on and directories

In Creator's **Governance** area, administrators can set up custom authentication, which enables single sign-on through SAML or JWT, so people sign in with their company identity provider. Creator also works with Zoho Directory for user, directory and domain management. Central sign-in means access can be removed in one place when a person leaves.

### 6.2 Multi-factor authentication and password policy

- **MFA:** Governance supports multi-factor authentication modes for sign-in.
- **Password policy:** require strong passwords so that users create secure credentials.
- **Session management:** control how long sessions last and how they end.
- **IP restrictions:** allow access only from approved networks where this suits the organization.

### 6.3 Administration of accounts

Add users deliberately and remove them promptly. Where several people build an app, Zoho advises adding them as developers instead of sharing admin credentials, so that actions can be traced to individuals.

241401049

# 7 Data Protection and Secure Integration

## 7.1 Protecting stored data

- **Encryption at rest:** all stored data is encrypted by default through the DEK and KEK model.
- **Field-level encryption:** certain fields support an additional layer of encryption for sensitive or personal data.
- **Report-level data masking:** hides parts of values in reports for users who do not need to see them.
- **PII and ePHI flags:** classify fields so their visibility is restricted by default.
- **Backups:** Zoho describes automatic backups as part of the platform, which supports recovery.

## 7.2 Secure scripting and integration

When Deluge scripts call other services, the way credentials are handled matters.

1. **Use Connections** for authorized access to other Zoho or third-party services, so tokens are stored centrally and not typed into scripts.
2. **Never hard-code keys or passwords** in Deluge, form fields or report filters.
3. **Validate input** on the server side in form events, not only in the user interface.
4. **Use API security settings** to control which clients may call the app's APIs.
5. **Follow data residency and privacy rules** when sending data to outside systems.

## 7.3 Records, files and email

Check who can download files, who can export reports and where notifications are sent. Email and file features can leak data if configured loosely, so restrict them in line with data sensitivity.

# 8 Governance and Administration Practices

## 8.1 The Governance module

Zoho Creator includes a **Governance** area for one-time setup of user identity and session controls. Per the documentation, it is available in paid plans, and only the super admin and admins can access it. Its main parts are security policies, custom authentication, directories and domains.

241401049

## 8.2 Controlled releases with environments

In Creator 6, **environments** provide a software development life cycle inside Creator. Apps are edited in **Development**, tested in **Stage**, and released to **Production**, where end users work. Production data stays independent of the other environments, which prevents test activity from damaging real records.

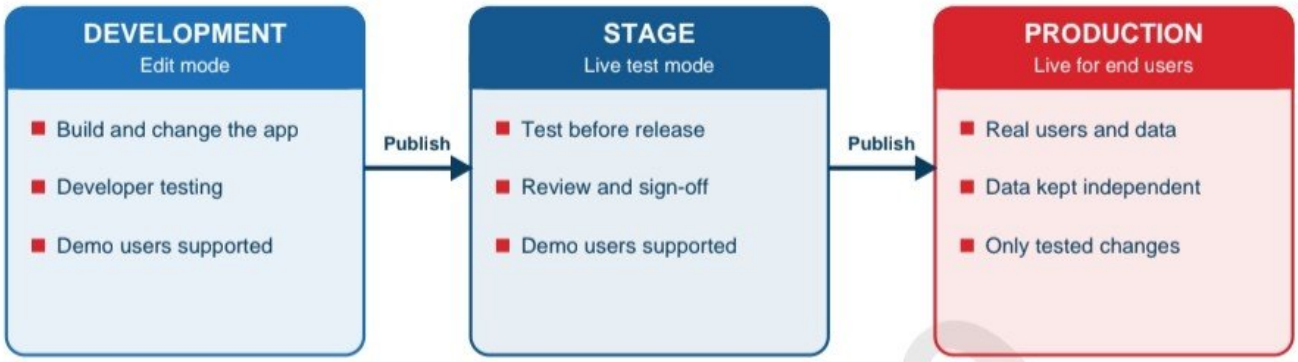



*Figure 2: Environments in Zoho Creator (Creator 6)*

## 8.3 Administration routines

| Practice | What to do |
|---|---|
| Ownership | Assign an owner and a backup owner to every app |
| Inventory | Keep a list of all apps, owners, data types and users |
| Naming and standards | Use consistent names for forms, fields, roles and scripts |
| Change review | Require a second person to review changes before they move to Stage |
| Audit trail review | Check activity records on a regular schedule |
| Access reviews | Every quarter, confirm that users and roles are still correct |
| Backups and recovery | Confirm backup and restore steps and test them |
| Retirement | Archive or remove apps that are no longer used |

## 8.4 Audit trail

Creator's audit trails keep a chronological record of activity. According to Zoho's guide, each entry shows who did the action, what it was, when it happened and what data was affected. These records support investigations, compliance checks and accountability. Review them regularly and restrict who can view them.

### 8.5 Roles in a governance model

- **Super admin and admins:** own security policies, governance settings and user management.
- **Developers:** build and change apps in development, without admin credentials.
- **Testers or reviewers:** check changes in stage.
- **Business owners:** approve who may use data and what they may do.
- **Auditors:** review logs and access.

## 9 Implementation Example: Leave Management App

### 9.1 The scenario

An organization builds a Leave Management app in Creator. Employees apply for leave, managers approve it, and HR keeps records. The app holds personal data, so access must be tightly controlled.

### 9.2 Role and permission design

| Role | Can see | Can do | Restricted |
|---|---|---|---|
| Employee | Own leave requests | Create and view own requests | No access to others' records, no export |
| Manager | Team members' requests (through role hierarchy) | Approve or reject team requests | No delete, no bulk edit |
| HR | All leave records | Edit records, manage balances | Salary and ID fields hidden by field permissions; limited export |
| App admin | Whole app, audit trail | Configure the app | Uses a named admin account, not a shared one |

### 9.3 Implementation steps

1. Create the roles and set the **role hierarchy** so managers sit above their teams.
2. Define **custom permissions** for each role at the form and report level.
3. Apply **field permissions** to hide sensitive fields from roles that do not need them.
4. Turn on **SSO and MFA** through Governance, and set the password and IP rules.
5. Add **server-side validation** in form events, and log sensitive actions.
6. Build and test in **Development**, publish to **Stage**, test with demo users, then publish to **Production**.
7. Schedule **access and audit reviews**.

### 9.4 Server-side validation in Deluge

The script below runs when a form is submitted. It blocks invalid input even if someone bypasses the screen. It is illustrative, and field names must be adapted to your app.

```
// Form: Leave_Request | Event: On Validate
if(input.From_Date > input.To_Date)
{
    alert "End date must be after start date.";
    cancel submit;
}
if(input.Days_Requested > 30)
{
    alert "Requests above 30 days need HR approval.";
    cancel submit;
}
```

### 9.5 Logging a sensitive action

A small audit form can record important actions in addition to the platform's own audit trail.

```
// Form: Leave_Request | Event: On Success (status changed)
insert into Audit_Log
[
    Action = "Leave status changed to " + input.Status
    Record_ID = input.ID.toString()
    Performed_By = zoho.loginuser
    Performed_At = zoho.currenttime
]
```

### 9.6 Row-level restriction in a report

To make a report show employees only their own records, a filter based on the signed-in user can be used, for example Added_User == zoho.loginuser. Combine this with permissions so that the restriction is not left to the screen alone.

## 10 Best Practices Checklist

| Area | Practice |
|---|---|
| Access | Apply least privilege; limit Export, Delete, View All and Bulk Edit |
| Roles | Keep few, clearly named roles; review them every quarter |
| Fields | Mark PII and ePHI fields; hide or mask them for roles that do not need them |
| Sign-in | Use SSO and MFA; enforce password and session policies; consider IP restrictions |
| Admin | Use named accounts; never share admin credentials; add builders as developers |
| Scripts | Use Connections; never hard-code secrets; validate on the server side |
| Releases | Develop, test in stage, then publish to production; keep production data separate |
| Monitoring | Review audit trails and access logs on a schedule |

| Area | Practice |
| --- | --- |
| Inventory | Keep a register of apps, owners and data types |
| Recovery | Know how backups work and test restore procedures |
| Training | Teach builders the security rules before they publish apps |

## 11 Challenges and Limitations

- **Plan and version differences:** some features, such as Governance and environments, depend on the plan or Creator version, so availability must be checked.
- **Shared responsibility:** platform security does not fix a badly configured role or an over-shared report.
- **Complexity of permissions:** combining roles, hierarchy, permissions and sharing rules can confuse administrators if not documented.
- **Citizen developer sprawl:** easy building means apps can multiply faster than oversight.
- **Human error and insider risk:** many incidents come from mistakes or misuse, which makes audit and training important.
- **Evolving features:** vendor features and policies change, so governance must be updated regularly.

## 12 Conclusion

Zoho Creator provides a strong base for secure low-code development: encryption, role-based access control, field-level controls, single sign-on and multi-factor authentication, audit trails, and environments for controlled releases. Using these features well depends on the organization.

The best results come from combining technical settings with governance routines: least-privilege access, central sign-in, protected sensitive data, tested releases, clear ownership and regular reviews. With these practices, an organization can keep the speed and flexibility of Creator while protecting its data and meeting its compliance duties.

## 13 References


- Zoho Creator Help, Understanding permissions: https://help.zoho.com/portal/en/kb/creator/developer-guide/application-settings/manage-and-configure-user-permissions/articles/understand-permissions
- Zoho Creator, Understand Governance: https://www.zoho.com/creator/help/governance/understand-governance.html
- Zoho Creator Help, Understanding environments: https://help.zoho.com/portal/en/kb/creator/developer-guide/environments/articles/understand-environments


241401049

- Zoho Creator FAQs, Privacy and Security: https://help.zoho.com/portal/en/kb/creator/faqs/getting-started/articles/faq-privacy-security
- Zoho Creator, App security: https://www.zoho.eu/creator/app-security.html
- Zoho Creator Evaluation Guide, Secure: https://www.zoho.com/creator/evaluation-guide/secure.html
- Zoho Creator Evaluation Guide, Govern: https://www.zoho.com/creator/evaluation-guide/govern.html
- Zoho Creator, Best practices: https://www.zoho.com/creator/best-practices.html

*Note: Feature availability, plan limits and certifications are set by Zoho and can change. Verify them in the official documentation and your own account.*

241401049